

# SOC 2 Readiness Assessment Report

*Prepared for Northstar, Inc. (mock engagement — portfolio demonstration)*

## Executive Summary

Northstar is pursuing SOC 2 Type I certification to meet a customer requirement and support continued enterprise growth. This assessment evaluated Northstar's current security posture against the SOC 2 Security Trust Services Criteria and found that while no formal security program exists today, the underlying foundation is stronger than it appears — Northstar already relies on infrastructure (AWS, GitHub) with strong built-in security capabilities. The primary gap is not technology, but the absence of documented policies, consistent enforcement, and defined processes.

### Key priorities, in order of risk:

1. Enforce multi-factor authentication and code review requirements already supported by existing tools.
2. Establish an incident response plan and verify backup recovery actually works.
3. Tighten access controls and formalize employee offboarding.

These top three items require low-to-moderate effort but address the highest-risk gaps, and can realistically be completed within the first two weeks of remediation. A full three-phase roadmap — moving from these quick wins through core process buildout to complete governance documentation — is detailed below.

This report includes a full control-by-control gap analysis, a prioritized risk register, a phased remediation roadmap, and three ready-to-adopt policies (Access Control, Incident Response, Vendor Management) to support immediate implementation. With focused effort over the next 6–8 weeks, Northstar will complete the readiness work outlined in this report. The independent CPA audit and formal SOC 2 Type I report follow this phase, typically adding another 4–6 weeks.

# 1. Scoping Memo

**Client:** Northstar, Inc.

**Objective:** Northstar has been asked by a prospective enterprise customer to provide a SOC 2 report as a condition of signing. This engagement prepares Northstar for a SOC 2 Type I examination by assessing current controls against the AICPA Trust Services Criteria, identifying gaps, and building a remediation roadmap.

## Report Type: Type I, not Type II

Type I assesses whether controls are suitably designed at a point in time, rather than tested for effectiveness over a period (Type II). Type I is the responsible starting point given Northstar has no formal security controls in place yet; enterprise customers routinely accept Type I as a first step, with Type II following once controls have run long enough to test.

## Trust Services Criteria in Scope

- Security (Common Criteria) — IN SCOPE, required for every SOC 2 report.
- Availability, Confidentiality, Processing Integrity, Privacy — OUT OF SCOPE. Not required by the prospect driving this engagement and not currently applicable to Northstar's business.

## System Description Boundary

In scope: production AWS environment (EC2, RDS, S3), the application codebase and CI/CD pipeline (GitHub), employee access to customer data, and third-party vendors that touch customer data (Stripe for billing). Out of scope: internal tools that don't touch customer data or production systems.

## Note on Management Assertion

As part of the formal SOC 2 examination (conducted separately by an independent CPA firm after this readiness phase), Northstar's leadership will be required to sign a management assertion — a formal statement affirming responsibility for the design and operation of the controls described in the system description. This readiness engagement prepares the underlying control environment and documentation; the assertion itself is executed during the audit phase.

# 2. Gap Analysis — Security (Common Criteria)

Each of the nine Common Criteria categories was assessed against Northstar's current state. The pattern across nearly every category: the gaps are primarily process and documentation gaps, not technology gaps.

| #   | Category                    | Current State                                                                          | Gap                                                        | Remediation                                                               |
|-----|-----------------------------|----------------------------------------------------------------------------------------|------------------------------------------------------------|---------------------------------------------------------------------------|
| CC1 | Control Environment         | No named security owner, no code of conduct, no background checks.                     | No governance/accountability structure.                    | Designate a security owner (fractional is fine); draft a code of conduct. |
| CC2 | Communication & Information | Informal Slack/email only; ad hoc customer security answers.                           | No formal policy communication process.                    | Draft core policies; standardize customer security Q&A process.           |
| CC3 | Risk Assessment             | Reactive, undocumented risk awareness (pursuing SOC 2 itself was a reactive decision). | No structured, recurring risk identification.              | Build a lightweight risk register, reviewed quarterly.                    |
| CC4 | Monitoring Activities       | Logs exist (CloudTrail, GitHub) but are not actively reviewed.                         | No proactive monitoring of control effectiveness.          | Establish a monthly access/log review cadence.                            |
| CC5 | Control Activities          | Tools support MFA/branch protection, but neither is enforced or documented.            | Technical capability exists without enforcement or policy. | Enforce MFA and branch protection; document as formal policy.             |

| #   | Category                  | Current State                                                                                                                                  | Gap                                                                                                                            | Remediation                                                                                                                            |
|-----|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| CC6 | Logical & Physical Access | Access often broader than necessary; no offboarding checklist; personal devices, no MDM; no SSO in place (each tool has separate credentials). | No least-privilege model, access lifecycle process, or centralized authentication.                                             | Least-privilege review; joiner/mover/leaver checklist; device policy; evaluate SSO as the company grows past a handful of tools.       |
| CC7 | System Operations         | No incident detection process; no IR plan; backups untested; no vulnerability scanning or formal patch management process.                     | No documented incident response; unverified recovery capability; unmanaged patching creates unaddressed known vulnerabilities. | Draft an incident response plan; perform a test backup restore; adopt a basic vulnerability scanning tool and a defined patch cadence. |
| CC8 | Change Management         | No required code review/approval before production deploy; the same engineer can write and deploy code with no separation of duties.           | No change control gate, documented policy, or separation between development and deployment.                                   | Require peer review via branch protection; document policy; ensure the person merging code is not the sole approver deploying it.      |
| CC9 | Risk Mitigation (Vendors) | No vendor inventory; vendor SOC 2 reports never requested.                                                                                     | No documented third-party oversight.                                                                                           | Build a vendor inventory; request vendor SOC 2 reports.                                                                                |

### 3. Risk Register

Findings are ranked by likelihood and impact (Low / Medium / High) rather than by control category alone, to reflect what should be addressed first.

| Priority | Category                          | Likelihood | Impact | Rationale                                                                                                |
|----------|-----------------------------------|------------|--------|----------------------------------------------------------------------------------------------------------|
| 1        | CC5 — Control Activities          | High       | High   | No enforced MFA is the most direct entry point for compromise, and the cheapest, fastest fix available.  |
| 2        | CC7 — System Operations           | Medium     | High   | Untested backups and no IR plan turn any incident into a worse outcome; addresses impact after the fact. |
| 3        | CC6 — Logical & Physical Access   | Medium     | High   | Over-provisioned or unrevoked access widens the blast radius of #1 and #2.                               |
| 4        | CC4 — Monitoring Activities       | Medium     | Medium | Determines how quickly a failure in #1–#3 would actually be noticed.                                     |
| 5        | CC8 — Change Management           | Medium     | Medium | Real but contained risk (a bad deploy), less connected to the access/incident cluster.                   |
| 6        | CC1 — Control Environment         | Low        | Medium | Foundational — enables fixing everything else — but not itself an acute risk.                            |
| 7        | CC2 — Communication & Information | Low        | Low    | Process gap; underlying risk is low.                                                                     |
| 8        | CC3 — Risk Assessment             | Low        | Low    | Process gap; underlying risk is low.                                                                     |
| 9        | CC9 — Risk Mitigation (Vendors)   | Low        | Low    | Underlying vendor risk is likely low; this is a documentation gap only.                                  |

### 4. Remediation Roadmap

Phase 1 = Weeks 1–2 (Quick Wins), Phase 2 = Weeks 3–5 (Core Buildout), Phase 3 = Weeks 6–8 (Governance & Documentation). Each item below is assigned an owner, a target timeline, and the evidence type that will demonstrate completion — the same structure a POA&M (Plan of Action & Milestones) tracker uses.

| Phase | #   | Action                                                     | Control Owner            | Target Timeline | Evidence Type                                                          |
|-------|-----|------------------------------------------------------------|--------------------------|-----------------|------------------------------------------------------------------------|
| 1     | CC5 | Enforce MFA org-wide; enable GitHub branch protection.     | Security Owner           | Week 1          | Screenshot of MFA enforcement setting; GitHub branch protection config |
| 1     | CC7 | Draft incident response plan; run one test backup restore. | Security Owner + Founder | Week 2          | Signed IR plan document; backup restore test log                       |
| 2     | CC6 | Access audit and                                           | Security Owner           | Week 3–4        | Access review log;                                                     |

| Phase | #   | Action                                                                                 | Control Owner    | Target Timeline | Evidence Type                                               |
|-------|-----|----------------------------------------------------------------------------------------|------------------|-----------------|-------------------------------------------------------------|
|       |     | least-privilege cleanup; build offboarding checklist.                                  |                  |                 | documented offboarding checklist                            |
| 2     | CC4 | Establish monthly log/access review cadence.                                           | Security Owner   | Week 4          | Documented review process; sample review log                |
| 2     | CC8 | Require peer code review before deploy; document policy; enforce separation of duties. | Engineering Lead | Week 5          | Change management policy document; branch protection config |
| 3     | CC1 | Designate security owner; draft code of conduct.                                       | Founder          | Week 6          | Signed code of conduct; documented role assignment          |
| 3     | CC2 | Draft and distribute core policies.                                                    | Security Owner   | Week 6–7        | Distributed policy documents; employee acknowledgment log   |
| 3     | CC3 | Build lightweight risk register process.                                               | Security Owner   | Week 7          | Risk register document                                      |
| 3     | CC9 | Build vendor inventory; request vendor SOC 2 reports.                                  | Security Owner   | Week 8          | Vendor inventory; collected vendor SOC 2 reports            |

## **5. Sample Policies**

### **5.1 Access Control Policy**

#### **1. Purpose**

This policy establishes requirements for granting, managing, and revoking access to Northstar's systems, applications, and data to ensure only authorized individuals can access company and customer information, and only to the extent necessary for their role.

#### **2. Scope**

This policy applies to all Northstar employees, contractors, and any third party granted access to production systems (AWS), source code repositories (GitHub), or customer data.

#### **3. Policy Statements**

3.1. Multi-Factor Authentication (MFA): MFA is required for all accounts with access to production systems, source code repositories, or customer data. No exceptions without documented, time-limited approval from the designated security owner.

3.2. Code Repository Protection: Branch protection must be enabled on all production repositories, requiring at least one peer review approval before code can be merged to the main branch.

3.3. Least Privilege: Access to systems and data is granted based on job role and limited to what is required to perform that role. Access requests outside standard role-based provisioning require written approval from the designated security owner.

3.4. Onboarding: New employees and contractors receive access only after a documented request specifying the systems and access level required for their role.

3.5. Offboarding: Access to all systems must be revoked within 24 hours of an employee's or contractor's departure, regardless of the reason for departure.

3.6. Device Security: Devices used to access production systems or customer data must have disk encryption enabled and a screen lock with automatic timeout. Use of personal (non-company-issued) devices for this purpose should be minimized where feasible, subject to approval by the designated security owner.

3.7. Separation of Duties: The individual who authors and merges a code change may not be the sole approver of its deployment to production; deployment requires review or approval from someone other than the change's author.

3.8. Single Sign-On (SSO): As Northstar's tool footprint grows, the designated security owner will evaluate adopting SSO to centralize authentication and simplify access reviews and offboarding.

#### **4. Enforcement**

Violations of this policy may result in revoked access and, depending on severity, disciplinary action. The designated security owner is responsible for periodic verification of compliance with this policy.

#### **5. Review Cadence**

This policy will be reviewed and updated at least annually, or upon significant changes to Northstar's systems or team structure.

### **5.2 Incident Response Policy**

#### **1. Purpose**

This policy establishes how Northstar detects, responds to, communicates about, and recovers from security incidents, to minimize damage, restore normal operations quickly, and meet obligations to customers and partners.

#### **2. Scope**

This policy applies to any suspected or confirmed security incident affecting Northstar's production systems (AWS), source code, customer data, or third-party services that support the business (e.g., Stripe, Google Workspace).

### **3. Policy Statements**

3.1. Incident Response Team & Roles: Northstar designates an Incident Response Lead (initially the founder or designated security owner) responsible for coordinating response efforts. Additional team members are designated as needed based on the nature of the incident. Roles and contact information are documented and kept current.

3.2. Severity Classification: Incidents are classified as Low (no customer data or production impact), Medium (limited impact to a single system or small number of users, contained quickly), or High (confirmed or suspected exposure of customer data, or significant production disruption). Classification determines escalation speed and whether customer notification is required.

3.3. Communication Protocols: For Medium and High severity incidents, the Incident Response Lead notifies affected internal stakeholders within 24 hours of detection. For High severity incidents involving confirmed customer data exposure, affected customers are notified in accordance with applicable legal requirements and contractual obligations. All incident communications are documented.

3.4. Detection & Escalation: Employees who observe a suspected security incident must report it immediately to the Incident Response Lead. Available system logs (e.g., AWS CloudTrail, GitHub audit logs) are reviewed as part of initial triage to assess scope.

3.5. Annual Testing: The incident response plan must be tested at least annually via a tabletop exercise simulating a realistic incident scenario. Testing must include verification that data can be successfully restored from backup.

3.6. Post-Incident Review: Following any Medium or High severity incident, a documented review is conducted to identify root cause, evaluate the effectiveness of the response, and determine any policy or control changes needed to prevent recurrence.

### **4. Enforcement**

Failure to report a known or suspected incident promptly is treated as a policy violation and may result in disciplinary action. The Incident Response Lead is responsible for verifying this policy is followed during and after incidents.

### **5. Review Cadence**

This policy will be reviewed and updated at least annually, or immediately following any High severity incident.

## **5.3 Vendor Management Policy**

### **1. Purpose**

This policy establishes how Northstar identifies, evaluates, and monitors third-party vendors with access to company systems or customer data, to ensure vendor relationships don't introduce unmanaged risk.

### **2. Scope**

This policy applies to all current and future third-party vendors and service providers that store, process, or have access to Northstar's systems or customer data, including but not limited to AWS, Stripe, and Google Workspace.

### **3. Policy Statements**

3.1. Vendor Inventory & Risk Categorization: Northstar maintains a documented inventory of all vendors with access to systems or customer data. Each vendor is categorized by risk tier (High/Medium/Low) based on the sensitivity of data or systems they can access.

3.2. Existing Vendor Catch-Up: Within 60 days of this policy's adoption, Northstar will complete an initial inventory and risk categorization of all current vendors (including AWS, Stripe, and Google Workspace) and request available compliance documentation (e.g., SOC 2 reports) from each.

3.3. Onboarding Due Diligence: Before engaging a new High or Medium tier vendor, Northstar reviews the vendor's available security/compliance documentation (e.g., SOC 2 report, security whitepaper) where available. Low tier vendors are added to the inventory without formal due diligence review.

3.4. Contractual Safeguards: For High tier vendors that process customer data, Northstar seeks a Data Processing Agreement (DPA) or equivalent contractual data protection terms where the vendor offers one.

3.5. Annual Review & Monitoring: The vendor inventory and risk categorization are reviewed at least annually. High tier vendors are re-checked for current compliance documentation at each annual review.

#### **4. Enforcement**

New vendor relationships involving High or Medium tier access must be reviewed under this policy before contracts are signed. The designated security owner maintains the vendor inventory and is responsible for tracking review cadence.

#### **5. Review Cadence**

This policy will be reviewed and updated at least annually.

*Prepared by Beth Gerharts — this report is a portfolio demonstration piece prepared for a fictional company and does not represent an actual audit or engagement.*